



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Normativa de Ciberseguridad

TEMA 2

Diseño de sistemas de gestión de cumplimiento normativo
Alberto Diéguez Álvarez

Caso práctico.....	3
Apartado 1: Contexto y alcance normativo.....	4
Apartado 2: Riesgos y obligaciones específicas	5
Apartado 3: Operación y evaluación del SGC.	6
Webgrafía.....	7

1.- Descripción de la tarea

Caso práctico

Cygnus Tech Solutions, S.L. es una empresa tecnológica española con 120 empleados, con sede en Barcelona. Su negocio principal es ofrecer servicios gestionados de infraestructura cloud (IaaS) y plataformas de analítica de datos (PaaS).

Sus dos clientes principales son:

1. Un **grupo hospitalario privado** (con presencia en varias CCAA), para el que Cygnus almacena y procesa los historiales clínicos electrónicos (datos de categoría especial según RGPD).
2. Una **empresa fintech** (entidad de dinero electrónico), que utiliza la plataforma de Cygnus para sus operaciones de pago y análisis de fraude en tiempo real.

Cygnus Tech ha crecido muy rápido y, aunque obtuvo la certificación **ISO 27001** el año pasado para ganar la confianza de sus clientes, una auditoría reciente ha señalado que su gestión del *cumplimiento normativo* (más allá de la seguridad de la información) es reactiva e inmadura. La dirección ha decidido implantar un SGC formal, alineado con la **ISO 37301**, para gestionar sus múltiples obligaciones.

¿Qué te pedimos que hagas?

Teniendo en cuenta el caso práctico de Cygnus Tech y los contenidos de la unidad, responde a las siguientes preguntas:

Apartado 1: Contexto y alcance normativo.

- Identifica y justifica brevemente la aplicabilidad de tres normativas clave para Cygnus Tech. Asegúrate de incluir al menos una de las regulaciones europeas de ciberseguridad más recientes (posteriores a 2022) que comentamos, explicando por qué le aplica (dada su actividad y clientes).

Buscando varias normativas me quedo con las siguientes.

1. Una de las más recientes: **Ley de Ciberresiliencia:**

- <https://www.incibe.es/empresas/blog/la-ley-de-ciberresiliencia-europea-se-publica-en-su-version-en-castellano>

Esta ley entra en vigor en el [Reglamento CRA](#), establece requisitos obligatorios de ciberseguridad para los productos que incluyen elementos digitales.

Aplica a Cygnus Tech porque esta desarrolla y además opera con servicios y plataformas digitales, ya que nos dicen en el caso práctico que ofrecen servicios gestionados de infraestructura cloud (IaaS).

2. **RGPD** (Reglamento General de Protección de Datos):

Este reglamento aplica a Cygnus Tech porque esta trata con datos personales y datos de salud. Aplicando estas normas aseguraríamos el buen tratamiento de los datos de los usuarios.

3. Directiva **NIS2**:

- <https://www.ccn.cni.es/es/normativa/directiva-nis2>

Buscando varias opciones me quedo con [NIS2 2022/2555](#). Esta directiva aplica a Cygnus Tech porque establece unos requisitos de ciberseguridad para empresas que proporcionan servicios digitales. También establece la notificación de incidentes para operadores de servicios esenciales y proveedores de servicios digitales.

- Basándote en los beneficios de un SGC descritos en los materiales (ISO 37301), ¿cuáles serían los dos beneficios principales que Cygnus Tech obtendría al implementar un SGC formal, más allá de la certificación ISO 27001 que ya posee?

Basándome en la webgrafía que añadido al final del documento, diría que los principales beneficios son:

1. Reducir el riesgo legal y sancionador.

Al implementar un SGC (Sistema de Gestión de Calidad), se reduce la posibilidad de que surja algún incumplimiento legal y a su debida sanción a causa de un ciberataque, malware...

2. Mejorar la confianza de los clientes.

Al implementar varias regulaciones los clientes tendrán más confianza en Cygnus Tech.

Apartado 2: Riesgos y obligaciones específicas

- Describe dos riesgos de incumplimiento material (no riesgos de ciberseguridad genéricos, sino de incumplimiento legal/normativo) a los que se enfrenta Cygnus. Uno debe estar relacionado con su cliente hospitalario y el otro con su cliente fintech.

Como riesgos de incumplimiento nombraría:

- Incumplimiento del RGPD. Este estaría relacionado con el cliente hospitalario, ya que una brecha de datos o un mal uso de los mismos, tanto personales como de salud, supondría una grave sanción.
- Incumplimiento de la normativa de servicios financieros.
 - <https://www.finance-watch.org/wp-content/uploads/2024/09/Introduction-to-EU-Financial-Regulation.pdf>
 - <https://www.boe.es/buscar/act.php?id=BOE-A-2018-16036>

Cualquier fallo en el cumplimiento de operaciones, transacciones o en la protección de los datos financieros, pueden derivar en sanciones.

- La [Ley 2/2023](#) (reguladora de la protección de las personas que informen sobre infracciones normativas) es de obligado cumplimiento para Cygnus (120 empleados). ¿Qué obligación específica impone esta ley a la organización en materia de canales, y qué riesgo principal (o dominio de la ISO 37301) ayudaría a mitigar su correcta implementación?

Como obligación específica en materia de canales, Cygnus Tech tiene la obligación de tener un canal interno de denuncias, y como se especifica en la normativa, tiene que ser confidencial y seguro.

- <https://www.laboral-social.com/canal-denuncias-interno-obligaciones-confidencialidad-sanciones>

Como riesgo principal que ayuda a mitigar es el **riesgo legal por incumplimiento normativo**.

- <https://www.compliance-antisoborno.com/cuales-son-las-consecuencias-del-incumplimiento-normativo/>

Al implementar correctamente un canal interno de denuncias, se reduce la posibilidad de sanciones por no detectar a tiempo cualquier infracción.

Apartado 3: Operación y evaluación del SGC.

- Nombra tres partes interesadas (internas o externas) clave para el SGC de Cygnus y describe una expectativa de cumplimiento principal que tendría cada una de ellas.
1. **Cientes, hospital y Fintech:** La expectativa sería el cumplimiento normativo, y por supuesto que sigan siendo nuestros clientes.
 2. **Directivos:** Reducir los riesgos legales y tener más reputación.
 3. **Empleados:** Tener clara la normativa y estar protegidos a denuncias.
- Propón un control (o medida de tratamiento) específico para cada uno de los dos riesgos de incumplimiento que identificaste en la pregunta 2.1.
 - Para **RGPD** propondría cifrar los datos clínicos, tener un control de accesos óptimo y tener auditorías periódicas.
 - Para el **incumplimiento de la normativa de servicios financieros** propondría una trazabilidad completa de todas las operaciones, es decir tener una visión completa de todas las operaciones y su gestión.

- Define dos Indicadores Clave de Cumplimiento (KCI) que la dirección de Cygnus podría utilizar para la "Evaluación del Desempeño" (Dominio 9 de la ISO 37301) de su nuevo SGC. (Deben ser métricas, no solo tareas).

Como indicadores KCIs (Key Control Indicators) definiría los siguientes.

- Porcentaje total de incumplimientos detectados y corregidos en plazo, para así poder ajustar el porcentaje a nuestro favor, mejorando los plazos de corrección.
- Número de incidentes por trimestre, para tener una visual del número total de incidentes para poder reducirlo, con otros trimestres, compararlos...

Webgrafía:

- <https://www.escuelaeuropeaexcelencia.com/2021/09/7-elementos-clave-de-un-programa-de-cumplimiento-iso-37301/>
- <https://www.egs.com/es/compliance-blog/sistema-de-gestion-de-compliance/>
- https://assets.kpmg.com/content/dam/kpmg/es/pdf/2016/12/Cuadernos_Legales_N3.pdf
- https://assets.kpmg.com/content/dam/kpmg/es/pdf/2016/12/Cuadernos_Legales_N4.pdf
- https://www.aenor.com/documents/d/guest/ebook_15_claves_compliance
- <https://calidadgestion.wordpress.com/tag/sistema-de-gestion-de-compliance/>
- <https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma/?c=N0065822>
- https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_ciberseguridad_gestion_riesgos_metad.pdf
- https://www.tendencias.kpmg.es/wp-content/uploads/2018/12/12_Factores_Independencia_031218.pdf